LOGION CASE 테스트 실행 매뉴얼

PC 2대 · RED 2명 / BLUE 2명 · 단계별 실행과 캡처 지점

문서 범위: 제공된 2026-11-04 LOGION 토폴로지(as-built) + 현재 대화에서 정리한 CASE 01~03 계획. 아래는 실행 지침이며 실제 공격 성공/탐지/차단은 시험 후 판정해야 한다.

01. PC 배치 및 팀원 분담

구분	가동 VM / 역할
PC-1 데이터망	VirtualBox 내부 네트워크로 Kali, pfSense Edge, pfSense Internal, WAF, WebAPI, MariaDB, Bastion, Office 테스트 PC를 CASE별 선택 실행
PC-2 관제망	Wazuh Manager·Indexer·Dashboard (10.10.40.100). PC-1 각 서버의 SOC NIC는 물리 LAN 브리지로 연결
RED 1 / RED 2	RED 1: CASE 01·02 공격 요청 및 캡처 / RED 2: 초기·변경 결과 검증, CASE 03 접근 시험, 재시험
BLUE 1 / BLUE 2	BLUE 1: pfSense·WAF·WebAPI 로그 및 방어 / BLUE 2: Wazuh·MariaDB·Bastion 로그와 판정

PC-1이 16GB라면 모든 VM을 동시에 켜지 않는다. CASE별 필요한 VM만 실행하고 종료한다. 실제 메모리 사용량 확인 후 가동 수를 결정한다.

02. CASE별 VM 실행 목록

CASE	PC-1 실행	PC-2 실행
01 배송지 바꿔치기	Edge + Internal + WAF + WebAPI + MariaDB + Kali	Wazuh
02 문서 업로드	Edge + WAF + WebAPI + Kali (업로드 기록 DB 저장 시 MariaDB 및 Internal 추가)	Wazuh
03 외주계정	Internal + Bastion + Office 테스트 PC (경로에 필요하면 Edge도 실행)	Wazuh

03. 공통 실행 순서 + 반드시 캡처할 때

순서	담당	실행 행동	캡처 시점/파일
01	BLUE 2	PC-2 Wazuh 시작: Manager, Indexer, Dashboard 실행 및 접속	CAP-00: Dashboard/서비스 화면
02	BLUE 1	PC-1에서 pfSense (CASE 필요 대상) 실행, NIC/규칙/라우트 확인	CAP-01: 인터페이스·규칙
03	BLUE 1·2	해당 CASE 서버 실행 후 공격자 VM/Office PC 실행	CAP-02: VirtualBox 실행 VM 목록
04	BLUE 1	각 서버 ip -br addr / ip route, 데이터망 통신 검증	CAP-03: IP·라우트; CAP-04: 서비스 연결
05	BLUE 2	Wazuh Agent active와 실제 최신 이벤트 수신을 따로 확인	CAP-05: Agent 상태·최신 이벤트
06	RED 2·BLUE 2	더미 데이터 초기값, 계정, 시간과 스냅샷/백업 확보	CAP-06: 테스트 전 상태·백업

참고: Agent의 Wazuh Manager 주소는 사용자의 요청에 따라 현재 설정 그대로 유지한다. ZeroTier 탈퇴 이후 실제 로그가 도착하는지는 별도 확인해야 한다.

CASE 01 | 배송지 바꿔치기 (BOLA)

목표: 고객 A로 로그인한 상태에서 고객 B의 테스트 주문 배송지를 무단 변경할 수 있는지 확인하고, 서버 측 소유권 검증 후 재시험한다.

필요 VM

PC-1 Kali 10.10.99.10 → Edge → WAF 10.10.10.5 → WebAPI 10.10.10.20 → Internal → MariaDB 10.10.20.10; PC-2 Wazuh

팀별 실행 순서 및 증빙 시점

순서	담당	해야 할 작업	바로 캡처할 증거
01	RED 1 / BLUE 2	더미 고객 A·B, 각 주문 ID, 배송지의 초기 상태 조회	C01-01: 변경 전 주문/배송지
02	RED 1 / BLUE 1	A 인증으로 본인 주문 변경 정상 요청; 응답·DB 기록 확인	C01-02: 정상 요청·응답
03	RED 1	같은 인증 상태에서 B 주문 ID를 대상으로 변경 요청	C01-03: 공격 요청·응답·시간
04	RED 2 / BLUE 2	B 배송지의 변경 여부 및 DB 감사/이력 조회	C01-04: DB 전후 상태
05	BLUE 1·2	API 감사로그, DB 감사로그, Wazuh 최신 이벤트·탐지 여부 판정	C01-05: 로그와 경고(있다면)
06	BLUE 1	로그인 사용자 ID와 주문 소유자 검증 적용, 거부 응답 설정	C01-06: 방어 코드·정책
07	RED 1·2	동일 요청 재전송하고 거부 응답 확인	C01-07: 재공격 요청·응답
08	BLUE 2	재공격 이후 DB 값 불변/추가 이력 없음 확인	C01-08: 최종 DB 상태

CASE 종료 판정

☐ 취약한 상태에서 허용/거부 결과가 기록됨

☐ BLUE가 로그 수집과 실제 경고 발생을 구별함

☐ 방어 후 동일 비인가 변경이 거부되고 DB 값이 유지됨

주의: 실제 HTTP URL, JSON 필드, 테스트 계정, 로그 경로는 구현 환경에서 확인해야 한다. 증빙 없는 성공·탐지 주장은 쓰지 않는다.

CASE 02 | 물류문서 업로드 취약점

목표: 허용하지 않은 무해한 시험 파일의 저장 여부를 확인하고 파일 형식 검증·저장 정책 수정 후 동일 파일을 재업로드한다.

필요 VM

PC-1 Kali → Edge → WAF 10.10.10.5 → WebAPI 10.10.10.20; DB에 기록하면 MariaDB/Internal도 가동. PC-2 Wazuh

팀별 실행 순서 및 증빙 시점

순서	담당	해야 할 작업	바로 캡처할 증거
01	RED 1 / BLUE 1	정상 PDF·비허용 무해 테스트 파일 준비, 허용 정책/저장 폴더 확인	C02-01: 파일/정책/초기 폴더
02	RED 1	정상 파일 업로드 후 응답 확인	C02-02: 정상 업로드 응답
03	RED 1	비허용 확장자/유형의 무해한 파일 업로드 요청	C02-03: 요청·응답·파일명
04	RED 2 / BLUE 1	서버 저장 폴더에서 실제 저장 여부 확인	C02-04: 저장 여부
05	BLUE 1·2	WAF/웹로그, Wazuh FIM 경로 및 이벤트 확인	C02-05: 로그·이벤트(있다면)
06	BLUE 1	확장자·MIME·실제 내용·크기 검증 및 저장 경로 정책 적용	C02-06: 변경 정책/설정
07	RED 1	동일 파일/요청으로 재업로드 시도	C02-07: 거부 응답
08	BLUE 1·2	파일 미저장 및 관련 차단 로그 확인	C02-08: 폴더·로그

CASE 종료 판정

☐ 비허용 파일의 저장 여부가 전후 비교됨

☐ Wazuh FIM 적용 경로를 확인했고 이벤트 유무를 사실대로 적음

☐ 방어 후 동일 파일이 저장되지 않음

주의: 실제 HTTP URL, JSON 필드, 테스트 계정, 로그 경로는 구현 환경에서 확인해야 한다. 증빙 없는 성공·탐지 주장은 쓰지 않는다.

CASE 03 | 외주 관리계정의 그림자

목표: 만료되었으나 아직 폐기되지 않은 실습용 외주 계정의 Bastion 로그인 가능 여부를 확인하고, 계정 폐기/권한 조치 후 거부를 검증한다.

필요 VM

PC-1 Office 협력업체 테스트 PC(10.10.30.x) → pfSense Internal (10.10.30.1 / 10.10.20.1) → Bastion 10.10.20.6:22. PC-2 Wazuh

팀별 실행 순서 및 증빙 시점

순서	담당	해야 할 작업	바로 캡처할 증거
01	RED 2 / BLUE 2	Office 테스트 PC IP, Bastion 실습 계정 및 계약 종료 가정 상태 확인	C03-01: 테스트 IP·계정 상태
02	RED 2 / BLUE 1	Office PC에서 Bastion TCP 22 연결 및 pfSense 허용 규칙 확인	C03-02: TCP 연결/규칙
03	RED 2	해당 실습 계정으로 SSH 로그인 시도	C03-03: 접속 성공/실패·시간
04	BLUE 1·2	pfSense·Bastion SSH 로그·Wazuh 이벤트 분석	C03-04: 인증/방화벽 로그
05	BLUE 2	테스트 계정 잠금 또는 폐기, 인증 키/권한 정리	C03-05: 계정 조치
06	RED 2	동일 계정·출발지에서 SSH 재접속	C03-06: 인증 거부
07	BLUE 1·2	SSH/방화벽 로그로 실제 차단 원인 확인	C03-07: 최종 로그

CASE 종료 판정

☐ Office 구간에 테스트 PC와 유효한 계정이 준비됨

☐ 초기 로그인 가능 여부와 SSH 로그가 연결됨

☐ 계정 폐기 이후 동일 계정 접근이 거부됨

주의: 실제 HTTP URL, JSON 필드, 테스트 계정, 로그 경로는 구현 환경에서 확인해야 한다. 증빙 없는 성공·탐지 주장은 쓰지 않는다.

최종 제출 체크리스트

구분	RED 제출	BLUE 제출
환경	VM·IP·테스트 계정·기준 데이터	pfSense·서비스·Agent 상태와 데이터 백업
공격 증거	실행 명령/요청, 응답과 시간	API/DB/WAF/SSH 등 연관 로그
결과	데이터 변경·파일 저장·접속 성공 여부	로그 수신과 경고 발화를 구별해 기록
방어	같은 조건 재공격 결과	바뀐 코드/정책/계정 설정
마무리	최종 요청·응답 캡처	DB 값 불변/파일 미저장/로그인 거부 확인

권장 증빙 폴더

LOGION_Evidence / 00_Preparation / CASE_01_BOLA / CASE_02_Upload / CASE_03_Bastion

사진 파일명 예: C01-03_Red_Attack.png, C01-05_Blue_Logs.png, C01-07_Retest.png

검사 시 핵심 기준

☐ 각 캡처에서 시스템/출발지/대상/시간/실제 결과가 확인되는가?

☐ 동일한 요청·계정·파일을 사용한 재시험인가?

☐ 차단 원인이 WAF·WebAPI·DB·SSH·pfSense 중 무엇인지 구분했는가?

☐ 민감한 비밀번호/토큰/개인정보를 마스킹했는가?

☐ 실제 동작을 확인하지 못했다면 “미실행 / 미확인”이라고 기록했는가?

기술 메모

제공된 토폴로지에서는 PC-1의 wan/dmz/srv/office가 VirtualBox 내부 네트워크이며, SOC만 브리지로 PC-2의 Wazuh와 연결된다. 현장 통신과 Wazuh 실제 로그 수신은 별도로 검증해야 한다. CASE 03 Office PC의 구체적인 IP와 실제 WebAPI 엔드포인트는 원본 문서에서 확인되지 않았다.